Secure by Design Principles

Security costs least when it is designed in from the first sketch. Bring this guide to design reviews: each principle has a plain meaning, an example and questions.

Built in, not bolted on. FDA calls the organized way of doing this a **Secure Product Development Framework (SPDF)**: security built into every phase of development, inside the quality system, design controls and risk files your teams already use. The later a flaw is found, the more it costs:

DESIGN	IMPLEMENTATION	BEFORE SUBMISSION	IN THE FIELD
Edit a requirement in a review.	Rewrite and re-review code.	Rework, re-test, maybe delay launch.	Fix every unit, tell every customer.

The core design principles

PRINCIPLE, IN PLAIN TERMS	DEVICE EXAMPLE	ASK IN A DESIGN REVIEW
01 Least privilege Every person and component gets only the access it needs.	DERMALENS Reviewers can view triage results but not change the model.	• Who needs this access, and who doesn't? • What could a stolen login for this role do?
02 Defense in depth Several independent layers, so one failure doesn't expose the patient.	FLOWGUARD A separate network, signed libraries and the pump's own dose limits.	• If this control fails, what stops an attacker next? • Do we rely on a network we don't control?
03 Secure by default Ship in the safest configuration; customers opt in to riskier options.	ORIONARM Ships with remote service off and no shared factory password.	• Are risky features off until the customer opts in? • Is there any shared or default password?
04 Minimize attack surface Remove every port, service and feature the product doesn't need.	CARDIAPACE Production transmitters have the debug port disabled.	• Is every port, service and feature needed in the field? • Are debug access and test accounts removed?
05 Fail safe On failure, fall back to a state that keeps the patient safe.	FLOWGUARD A pump that can't reach its server keeps the last good drug library.	• If the link drops, does therapy continue? • Could the control itself stop therapy (an expired certificate)?
06 Authenticate and authorize Check who is connecting and what they may do.	CARDIAPACE The implant obeys only an authorized clinic programmer.	• Who is connecting, and what may they do? Where is that enforced? • How does this work in an emergency?
07 Protect integrity Software, settings and data can't be changed undetected; updates are signed.	FLOWGUARD Pumps reject unsigned firmware or drug libraries.	• Is every update, setting and file checked before use? • What happens, safely, when a check fails?
08 Log and detect Record security events so problems can be noticed and investigated.	ORIONARM Logs who used remote service, when, and what changed.	• Which security events do we record? Who reads them? • Would we, or the customer, notice an attack?
09 Design for updates Plan from day one how fixes reach every device for its whole service life.	CARDIAPACE Implant firmware needs a validated update path through the transmitter or clinic.	• How will a fix reach every unit, and how fast? • Is each component supported as long as the product?

Patient safety lens

"Fail safe" means therapy continues safely, not that the device locks up: a pump that stops because a certificate expired can harm a patient as surely as an attack.

Threat modeling, risk and requirements

Threat modeling is a structured look at a design that asks plain questions:

1. How does this product work, and what does it connect to?
2. What could someone do to it on purpose?
3. What will we do about it?

It works best as a team exercise (engineers, product, clinical, product security), started while the architecture is still on a whiteboard and updated as the design changes.

Exploitability, not probability. Attacks don't follow failure rates: a weakness can be used again and again, and once a method is published, anyone can use it. So security risk is rated by **exploitability** (the access, skill and tools needed) and **severity** for patients. Risks that could cause harm feed the safety risk file.

ORIONARM Stolen service credentials could let someone change console software remotely: high exploitability, high severity. The response becomes a testable requirement: *"Remote service sessions shall require multi-factor authentication and approval by an on-site user."*

FDA's security control categories

FDA's premarket guidance recommends that a design address these categories, and that the submission show how. They make a useful checklist for any market.

CONTROL CATEGORY	THE DESIGN QUESTION	EXAMPLE (FICTIONAL DEVICES)
Authentication	Who or what is connecting?	A CardiaPace implant checks the clinic programmer
Authorization	Can each user do only what it should?	Only pharmacy can publish a FlowGuard drug library
Cryptography	Are we using well-established methods?	Standard encryption for DermaLens uploads
Integrity	Would we detect unauthorized changes?	Signed OrionArm software updates
Confidentiality	Who can see sensitive data?	Encrypted patient data in the CardiaPace portal
Event detection and logging	Would anyone notice an attack?	OrionArm remote-session logs
Resiliency and recovery	Does it keep working safely, and recover?	FlowGuard keeps the last good drug library
Updatability	Can we deliver fixes to every unit in time?	Validated updates for CardiaPace transmitters

The SBOM: the product's ingredients list

Most code in a device was written by someone else: commercial (OrionArm's operating system), open-source (DermaLens image libraries) or off-the-shelf. You inherit its weaknesses.

A **software bill of materials (SBOM)** lists every software component with its name, version and supplier, plus (FDA expects) its support status and end-of-support date. When a flaw hits a popular library, it answers "which of our products are affected?" in minutes, not weeks. For US cyber devices, the law requires an SBOM in the premarket submission.

Bring three facts to the design review for every new component:

VERSION	SUPPLIER	SUPPORT
which one?	who supports it?	until when?

If nobody knows the last answer, raise it now, not in year eight. SBOMs are usually machine-readable (SPDX or CycloneDX).

Device trade-offs

Every control must also work for a nurse at 3 a.m., a surgeon mid-procedure or a patient at home.

Usability. Too hard gets worked around: gloved nurses can't type long passwords on every FlowGuard pump; badge taps can work.

Emergency access. CardiaPace must stay programmable away from its usual clinic, so a design might rely on close proximity, not a password nobody in the emergency room knows.

Clinical workflow. An OrionArm update is scheduled with the hospital, never sprung between operations.

Battery. On an implant, every extra calculation draws on a battery replaced only by surgery.

Validation burden. Every change needs verification and validation: make updates routine.

Decide explicitly: involve clinical users early, add compensating controls where needed, record the rationale in the risk file, and tell customers in the labeling what they must do.

CardiaPace, FlowGuard, DermaLens and OrionArm are fictional devices created for training. Training material, not legal or regulatory advice.